

Fundamentals of Information Systems Security

COBIT 2019 Framework Overview

Governance and Management of Enterprise Information and Technology

Version: 2019

Publisher: ISACA

Objectives: 40

Domains: 5

Contents

1	Introduction to COBIT	3
1.1	Overview	3
1.2	Purpose and Scope	3
1.3	Key Concepts	3
2	COBIT 2019 Core Model	4
2.1	Governance and Management Objectives	4
2.2	The Five Domains	4
3	Domain Detail: Evaluate, Direct, Monitor (EDM)	5
3.1	Overview	5
3.2	Governance Objectives	5
4	Domain Detail: Align, Plan, Organize (APO)	5
4.1	Overview	5
4.2	Management Objectives	5
5	Domain Detail: Build, Acquire, Implement (BAI)	7
5.1	Overview	7
5.2	Management Objectives	7
6	Domain Detail: Deliver, Service, Support (DSS)	7
6.1	Overview	7
6.2	Management Objectives	7
7	Domain Detail: Monitor, Evaluate, Assess (MEA)	9
7.1	Overview	9
7.2	Management Objectives	9
8	Governance Components	10
8.1	The Seven Components	10
8.2	Component Relationships	10
9	COBIT 2019 vs. COBIT 5	10
9.1	Key Changes	10
9.2	Key Improvements	10

10 Practical Application	10
10.1 Strategy to Operations Journey	11
10.2 Key Questions for Strategy (APO02)	11
10.3 Implementation Approach	11
11 References	11

1 Introduction to COBIT

1.1 Overview

COBIT (Control Objectives for Information and Related Technologies) is an IT governance and management framework designed to help organizations create value from their IT initiatives, better manage their risk, and optimize resources[reference:114]. COBIT 2019 is the latest iteration of the framework, providing comprehensive guidance on how governance and management should be defined within an enterprise[reference:115].

1.2 Purpose and Scope

The primary purposes of COBIT 2019 are to[reference:116]:

- Assist enterprises in making key governance system design decisions
- Help organizations successfully achieve enterprise goals and objectives[reference:117]
- Provide guidance on how governance and management should be defined within an enterprise[reference:118]
- Bridge the gap between business goals and IT capabilities

1.3 Key Concepts

Core Concepts

- **Governance:** The system by which enterprises are directed and controlled
- **Management:** The planning, building, running, and monitoring of activities
- **Governance Objective:** A set of related practices and activities to achieve a specific governance goal
- **Management Objective:** A set of related practices and activities to achieve a specific management goal
- **Governance Components:** 7 components collectively responsible for achieving objectives[reference:119]

2 COBIT 2019 Core Model

2.1 Governance and Management Objectives

COBIT 2019 defines 40 governance and management objectives[reference:120][reference:121]:

- **Governance Objectives:** 5 objectives contained in the Evaluate, Direct and Monitor (EDM) domain[reference:122]
- **Management Objectives:** 35 objectives contained in 4 domains[reference:123]

Governance Objectives (EDM Domain)

1. EDM01: Ensure Governance Framework Setting and Maintenance
2. EDM02: Ensure Benefits Delivery
3. EDM03: Ensure Risk Optimization
4. EDM04: Ensure Resource Optimization
5. EDM05: Ensure Stakeholder Transparency

2.2 The Five Domains

The governance and management objectives in COBIT 2019 are grouped into 5 domains[reference:124][reference:125]:

Domain	Code	Description
Evaluate, Direct, Monitor	EDM	Governance domain where the governing body evaluates strategic options, directs senior management on the chosen strategic options, and monitors the achievement of the strategy[reference:126]
Align, Plan, Organize	APO	Addresses the overall organization, strategy, and supporting activities for information and technology (I&T)[reference:127]
Build, Acquire, Implement	BAI	Addresses the definition, acquisition, and implementation of I&T solutions and their integration in business processes[reference:128]
Deliver, Service, Support	DSS	Addresses the operational delivery and support of I&T services, including security[reference:129]
Monitor, Evaluate, Assess	MEA	Addresses performance monitoring and conformance of I&T with internal performance targets, internal control objectives, and external requirements[reference:130]

3 Domain Detail: Evaluate, Direct, Monitor (EDM)

3.1 Overview

The EDM domain contains the governance objectives[reference:131]. In this domain, the governing body evaluates strategic options, directs senior management on the chosen strategic options, and monitors the achievement of the strategy[reference:132].

3.2 Governance Objectives

ID	Objective	Key Activities
EDM01	Ensure Governance Framework Setting and Maintenance	Establish and maintain a governance framework for I&T
EDM02	Ensure Benefits Delivery	Optimize the value of IT-enabled investments
EDM03	Ensure Risk Optimization	Ensure risk appetite and tolerance are understood
EDM04	Ensure Resource Optimization	Optimize the use of IT resources
EDM05	Ensure Stakeholder Transparency	Ensure transparent communication with stakeholders

4 Domain Detail: Align, Plan, Organize (APO)

4.1 Overview

The APO domain addresses the overall organization, strategy, and supporting activities for information and technology (I&T)[reference:133]. It contains 14 management objectives[reference:134].

4.2 Management Objectives

ID	Objective	Key Activities
APO01	Managed I&T Management Framework	Establish and maintain a management framework for I&T
APO02	Managed Strategy	Provide a holistic view of the current business and I&T environment, the future[reference:135]
APO03	Managed Enterprise Architecture	Establish and maintain an enterprise architecture
APO04	Managed Innovation	Maintain an awareness of technology trends
APO05	Managed Portfolio	Ensure optimal investment in I&T resources
APO06	Managed Budget and Costs	Manage I&T budget and costs
APO07	Managed Human Resources	Ensure optimal human resource management
APO08	Managed Relationships	Manage relationships with stakeholders
APO09	Managed Service Agreements	Align service agreements with business requirements

APO10	Managed Suppliers	Manage supplier relationships and performance
APO11	Managed Quality	Ensure quality in I&T processes
APO12	Managed Risk	Continuously manage I&T risk
APO13	Managed Security	Manage security within the I&T environment
APO14	Managed Data	Ensure proper management of data assets

5 Domain Detail: Build, Acquire, Implement (BAI)

5.1 Overview

The BAI domain addresses the definition, acquisition, and implementation of I&T solutions and their integration in business processes[reference:136]. It contains 11 management objectives[reference:137].

5.2 Management Objectives

ID	Objective	Key Activities
BAI01	Managed Programs	Manage I&T programs and projects
BAI02	Managed Requirements Definition	Define functional and technical requirements
BAI03	Managed Solutions Identification and Build	Identify and build I&T solutions
BAI04	Managed Availability and Capacity	Ensure availability and capacity of resources
BAI05	Managed Organizational Change Enablement	Manage the impact of change on the organization
BAI06	Managed IT Changes	Manage IT changes in a controlled manner
BAI07	Managed IT Change Acceptance and Transitioning	Ensure smooth transition of changes into production
BAI08	Managed Knowledge	Ensure knowledge is maintained and shared
BAI09	Managed Assets	Manage IT assets throughout their life cycle
BAI10	Managed Configuration	Maintain configuration management
BAI11	Managed Projects	Manage IT projects and programs

6 Domain Detail: Deliver, Service, Support (DSS)

6.1 Overview

The DSS domain addresses the operational delivery and support of I&T services, including security[reference:138]. It contains 6 management objectives[reference:139].

6.2 Management Objectives

ID	Objective	Key Activities
DSS01	Managed Operations	Ensure efficient and effective IT operations
DSS02	Managed Service Requests and Incidents	Manage service requests and incidents
DSS03	Managed Problems	Identify and resolve problems
DSS04	Managed Continuity	Ensure business continuity in the event of disruptions
DSS05	Managed Security Services	Manage security services and controls

DSS06	Managed Business Process Controls	Ensure business process controls are in place
-------	-----------------------------------	---

7 Domain Detail: Monitor, Evaluate, Assess (MEA)

7.1 Overview

The MEA domain addresses performance monitoring and conformance of I&T with internal performance targets, internal control objectives, and external requirements[reference:140]. It contains 4 management objectives[reference:141].

7.2 Management Objectives

ID	Objective	Key Activities
MEA01	Managed Performance and Conformance Monitoring	Monitor and measure IT performance
MEA02	Managed System of Internal Control	Monitor and evaluate the internal control system
MEA03	Managed Compliance with External Requirements	Ensure compliance with external laws and regulations
MEA04	Managed Assurance	Provide assurance on IT governance and management

8 Governance Components

8.1 The Seven Components

COBIT 2019 defines 7 components that are collectively responsible for achieving governance and management objectives[reference:142]:

Component	Description
Processes	Activities with defined inputs, outputs, and outcomes
Organizational Structures	Roles, responsibilities, and reporting lines
Culture, Ethics, and Behavior	The values and behaviors that guide the organization
Information	Data and information used in decision-making
Services, Infrastructure, and Applications	The technology resources that support operations
People, Skills, and Competencies	The knowledge and capabilities of personnel
Policies and Procedures	The rules and guidelines that govern behavior

8.2 Component Relationships

Failure of a single component could result in failure to achieve the objective; hence, the review process should include all the COBIT components of a governance system[reference:143].

9 COBIT 2019 vs. COBIT 5

9.1 Key Changes

Aspect	COBIT 5	COBIT 2019
Governance Principles	5	6[reference:144]
Governance/Management Objectives	37	40[reference:145]
Domains	5	5
Focus	Principles-based	Design-based

9.2 Key Improvements

- More flexible and customizable framework
- Enhanced guidance on governance system design
- Updated to reflect current technology trends
- Improved performance management model[reference:146]
- Better integration with other frameworks

10 Practical Application

10.1 Strategy to Operations Journey

A recent professional focus has been in the area of helping organizations move from strategy planning to operational results[reference:147]. In the COBIT world, this means the journey from EDM to MEA[reference:148].

10.2 Key Questions for Strategy (APO02)

For APO02 (Managed Strategy), organizations should consider[reference:149]:

1. Does the enterprise have a strategy?[reference:150]
2. Is it the "right" strategy?[reference:151]
3. Is the organization ready to take the journey?[reference:152]
4. How does the organization know if it is the correct journey?[reference:153]

10.3 Implementation Approach

1. **Assess Current State:** Evaluate current governance and management practices
2. **Define Target State:** Establish desired governance and management objectives
3. **Identify Gaps:** Determine gaps between current and target states
4. **Develop Roadmap:** Create a plan to address identified gaps
5. **Implement and Monitor:** Execute the plan and monitor progress

11 References

- ISACA, COBIT 2019 Framework: Introduction and Methodology[reference:154]
- ISACA, COBIT 2019 Framework: Governance and Management Objectives[reference:155]
- ISACA, COBIT 2019 Design Guide
- ISACA, COBIT 2019 Implementation Guide
- ISACA, COBIT 2019 Performance Management Guide